

Manual Security Checks

Test flows documented in UI_TEST_FLOWS.md

Stored XSS: submit `<img src=x onerror=alert(document.domain)>` as review text → renders as literal text, no dialog

Reviews

☆☆☆☆☆

Average—nothing special.

Delete

☆☆☆☆☆

Delete

Write a review

What did you think of this plushie?

Rating

5 - excellent

Submit review

DevTools - localhost/

Elements Console Sources **Network** Performance Memory Application Security Recorder

☐ Preserve log ☐ Disable cache No throttling

Filter ☐ Invert More

Name	X	Headers	Preview	Response	Initiator	Timing	Cookies
019ead24-762a-78f8-89d0-09506c5bf8f4	1			[			
019ead24-762a-78f8-89d0-09506c5bf8f4	-			{			
image	-			"id": "019ead24-7fd1-7f4a-88ef-6a25e04b88a3",			
blob:http://localhost/a9d2186f-2ce2-4eee...	-			"rating": 3,			
019ead24-762a-78f8-89d0-09506c5bf8f4	-			"review_text": "Average-nothing special.",			
019ead24-762a-78f8-89d0-09506c5bf8f4	-			"reviewer_id": "00000000-0000-0000-0000-0000000000a1"			
019ead24-762a-78f8-89d0-09506c5bf8f4	-			},			
019ead28-92cb-764f-b67f-232b26b9fdc5	-			{			
019ead24-762a-78f8-89d0-09506c5bf8f4	-			"id": "019ead24-7fdd-768d-a92f-0262cc6cb457",			
019ead24-7fe8-70ba-b607-85b277dd4a1f	-			"rating": 5,			
019ead24-762a-78f8-89d0-09506c5bf8f4	-			"review_text": "The fluffiest plushie I've ever hugged.",			
019ead24-762a-78f8-89d0-09506c5bf8f4	-			"reviewer_id": "00000000-0000-0000-0000-0000000000a1"			
019ead24-7fdd-768d-a92f-0262cc6cb457	-			},			
019ead24-762a-78f8-89d0-09506c5bf8f4	-			{			
019ead24-762a-78f8-89d0-09506c5bf8f4	-			"id": "019ead24-7fe8-70ba-b607-85b277dd4a1f",			
019ead24-762a-78f8-89d0-09506c5bf8f4	-			"rating": 4,			
019ead24-762a-78f8-89d0-09506c5bf8f4	-			"review_text": "Cuter in person than in photos.",			
019ead24-762a-78f8-89d0-09506c5bf8f4	-			"reviewer_id": "00000000-0000-0000-0000-0000000000a1"			
	-			},			
	-			{			
	-			"id": "019ead28-92cb-764f-b67f-232b26b9fdc5",			
	-			"rating": 5,			
	-			"review_text": "",			
	-			"reviewer_id": "00000000-0000-0000-0000-0000000000a1"			
	-			}			
	-			]			

Item name (merchant) — create a product named `

New product

Name

<img src=x onerror=alert(dc

Description

ssss

Price (DKK)

100

Age group

1+

Stock

10

Type

dog

Visibility

Public — visible to everyone



Material

acrylic

Image (JPEG/PNG, max 2 MB)



Choose File CW484.jpg

Create product

```
<img src=x
onerror=alert(document.domain)>
```



100 DKK

ssss

Age group 1+
Type dog
Material acrylic
In stock 10

EditDelete

My products

New



secret prototype plushie1319.62 DKK

e. ville3011.52 DKK

sue ridge3611.04 DKK

PRIVATE



liv good4399.23 DKK

nick l. andime1454 DKK

tom katt267.35 DKK



ed jewcation4582.84 DKK

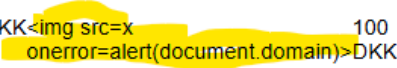
kanna mull3059.22 DKK

helen highwater523.7 DKK



joe kerr3553.5 DKK

kilene west4249.34 DKK



100DKK

Username (registration) — use the short variant `<img src=x onerror=alert(1)>` (28 chars, username is capped at 30) → header shows literal text.

Register account

Username

Street

Password

City

Email

Postal code

Phone Number

Country

Create Account

Cancel

uffy Plushies



Evidence: after storing a payload, the DB row holds it raw/unescaped → proves the defence is output encoding at render, not input stripping.

```
1 • SELECT * FROM `fluffy-plushies-identity`.user;
```

deleted	created_at	address_id	id	email	encoded_password	phone	username	role
0	2026-06-09 16:08:29.128180	BLOB	BLOB	merchant@merchant.com	{bcrypt}\$2a\$10\$Bj3dhEij...	+35834343434	merchant	MERCHANT
0	2026-06-09 16:08:29.183123	BLOB	BLOB	user@user.com	{bcrypt}\$2a\$10\$9QafOu/...	1234567890	user	USER
0	2026-06-09 16:08:29.054339	BLOB	BLOB	admin@admin.com	{bcrypt}\$2a\$10\$b9wVyH...	1234567890	admin	ADMIN
0	2026-06-09 16:37:59.790249	BLOB	BLOB	malicious@me.com	{bcrypt}\$2a\$10\$xO.Jv5i...	12121212		USER
NULL	NULL	NULL	NULL	NULL	NULL	NULL	NULL	NULL

Tampered JWT in localStorage (edit a character) → app treats you as logged out

http://localhost

Key	Value
jwt	eyJhbGciOiJIUzUxMiJ9.eyJzdWIiOiIwMTIiYWQzZi03ZDZILTczYTUyYXN1h'

http://localhost

Key	Value
jwt	eyJhbGciOiJIUzUxMiJ9.eyJzdWIiOiIwMTIiYWQzZi03ZDZILTczYTUyYXN1h'

t us

Contact

Careers

Sign up

Login

Fluffy Plushies



DevTools - localhost/

Elements Console Sources Network Performance

Application

- Manifest
- Service workers
- Storage

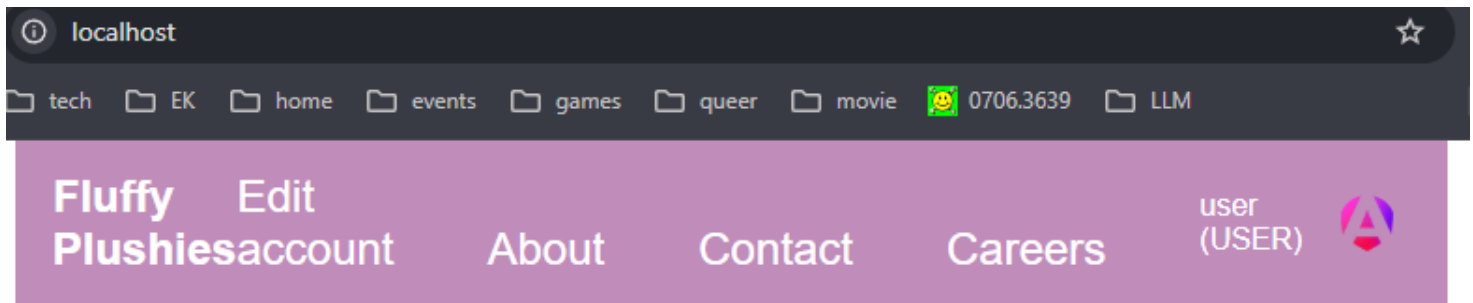
Storage

- Local storage
- http://localhost**
- Session storage
- Extension storage
- IndexedDB
- Cookies
- Private state tokens
- Internet group

http://localhost

Key	Value
-----	-------

CSRF PoC: while logged in, open a local `csrf-poc.html` that auto-submits `POST /inventory/items` → backend 401 (no cookie to ride, header not attached by attacker page).



CSRF proof-of-concept

This page is a stand-in for a malicious site on a **different origin**. Open it (e.g. via `file:///`) in the same browser where you are logged in to the shop, and it will auto-submit a cross-site `POST` to the backend's protected create-item endpoint.

If the session were a cookie, the browser would attach it automatically and the forged request would succeed (classic CSRF). Here the session is a JWT held in `localStorage` and sent as an `Authorization: Bearer` header by the app's own code. This page cannot read that token or set the header on a cross-site form, so the request arrives **unauthenticated** and the backend answers **401**.

You will not see the 401 on this page. The backend's response carries `X-Frame-Options: DENY`, so the browser refuses to render it in the frame below — it stays blank by design, which is itself a second (anti-framing) defence. To see the proof, open **DevTools** → **Network**, find the `POST /inventory/items` request, and confirm: status **401**, with **no** `Authorization` header and **no** cookie on the request.

A screenshot of a web browser's DevTools console. The 'Network' tab is selected, showing a list of requests. The first request, named 'items', has a status of '(blocked:origin)'. The 'Console' tab is also open, showing several error messages. The first message is 'Failed to load resource: the server responded with a status of 401 ()', where '401' is circled in red. Other messages include 'Refused to display 'http://127.0.0.1:8082/' in a frame because it set 'X-Frame-Options: DENY'' and 'Unsafe attempt to load URL http://127.0.0.1:8082/inventory/items from frame with URL chrome://...'. The browser's address bar shows the URL 'localhost:63343/fluffy-plushies-webshop/Documentation/poc/csrf-poc.html?_ijt=14uajor8ggv5tnr98j5msk8oud'.